

KMS at the edges: rotation, multi-Region keys, BYOK and external key stores

Two of these are named as new content in SCS-C03, and both appear almost nowhere in your question bank.

Rotation changes the **key material**. The key ID, ARN and alias never change.

Automatic rotation

- ◆ For **customer managed keys**. KMS rotates the material on a schedule; existing data needs no re-encryption.
- ◆ Period **configurable from 90 to 2,560 days** (~7 years). Default 365.
- ◆ **AWS managed keys rotate yearly, not configurable**. Changed from ~3 years in May 2022.
- ◆ **Symmetric encryption keys only**. Not asymmetric, HMAC, imported, or custom key store.
- ◆ AWS owned keys are rotated by the owning service. No visibility, no say.

ON THE EXAM

The configurable period is newer than most material, which says 'annually' and stops.

On-demand rotation

- ◆ **RotateKeyOnDemand** rotates immediately, whether or not automatic rotation is on.
- ◆ It **does not disturb the automatic schedule**.
- ◆ There is a **lifetime limit per key** – an incident tool, not a routine one.
- ◆ **June 2025: available for imported key material**. Import the new material first, then rotate.
- ◆ **Not available for AWS managed keys**. ListKeyRotations shows every material version.

ON THE EXAM

The answer to 'we think the key material was exposed'. Rotate now, keep the ARN.

Multi-Region keys

- ◆ A **primary** plus **replicas** in other Regions, sharing the **same key material** and key ID.
- ◆ **Any related key can decrypt another's ciphertext** – even ciphertext predating that replica.
- ◆ Encrypt in one Region, decrypt in another, with **no cross-Region KMS call**.
- ◆ **You cannot convert a single-Region key**. Decided at creation.
- ◆ Each replica is charged per key and per request **in its own Region**.

ON THE EXAM

For disaster recovery and low-latency reads. Not a way to share one policy across Regions.

What is shared, and what is not

- ◆ **Key policies are independent.** Replicating does not keep them in step afterwards.
- ◆ **Grants, aliases and tags are per-Region** too.
- ◆ **Rotation is shared.** Enable, disable and rotate on-demand **only on the primary.**
- ◆ **KMS encrypts nothing with new material until every replica has it.**
- ◆ For **imported** material, import the same material into **each replica individually.**

ON THE EXAM

Same material, separate governance. The most examinable fact about MRKs.

Imported key material, and how it differs

- ◆ Create a key with **origin EXTERNAL**, download a wrapping key and import token, wrap your material, import it.
- ◆ **AWS keeps no copy you can restore from.** Lose the material and the data is unrecoverable.
- ◆ Material can be given an **expiry**, after which the key is unusable until re-imported.
- ◆ **No automatic rotation.** On-demand since June 2025, and you supply the new material.
- ◆ The reason to accept all that: you generated it, so you can **prove provenance and destroy it** outside AWS.

ON THE EXAM

Skill 5.3.3 asks for exactly this comparison: provenance bought with lifecycle responsibility.

Imported material, or an external key store?

IMPORTED KEY MATERIAL

You generated it

- Material is imported into KMS
- KMS performs the cryptography
- You can prove provenance and expire it
- No automatic rotation

EXTERNAL KEY STORE (XKS)

It never enters AWS

- Material stays in your key manager
- Every operation happens in your HSM
- You own availability and latency
- Rotation happens outside KMS entirely

THE TIEBREAKER

'We generated the key' points at import. 'The key material must never be inside AWS' points at an external key store.

External key stores and CloudHSM key stores

- ◆ Both are **custom key stores**. The key presents as an ordinary KMS ARN, so consumers need no changes.
- ◆ **CloudHSM key store** – material in your single-tenant cluster, still inside AWS.
- ◆ **External key store** – material entirely outside AWS, via an XKS proxy you run.
- ◆ **Neither supports KMS rotation**. You rotate in the external manager or in CloudHSM.
- ◆ If your HSM or proxy is down, **every operation using that key fails**.

ON THE EXAM

You trade AWS's availability engineering for control. That is the whole decision.

What can rotate, and how

KEY	AUTOMATIC	ON - DEMAND
Customer managed, symmetric	Yes - 90 to 2,560 days	Yes
Customer managed, asymmetric or HMAC	No	No
Imported key material	No	Yes, since June 2025
CloudHSM or external key store	No	No - rotate outside KMS
AWS managed	Yes - every year, fixed	No
AWS owned	Managed by the owning service	No

ON THE EXAM

Only one row supports both. Any rotation requirement in a scenario should send you straight to this table.

A payments company imports its own key material into KMS so it can demonstrate provenance to its regulator. A new control requires the key material to be rotated every 90 days, without changing the key ARN, because hundreds of resources reference it.

An engineer enables automatic key rotation on the key and sets the period to 90 days. The API call fails.

Why, and how should the requirement be met?

- A 90 days is below the minimum rotation period; set it to 365 days instead
- B Automatic rotation is not supported for imported material; import new material and use on-demand rotation
- C The key must be converted to a multi-Region key before rotation can be enabled
- D Delete the key and create a new one every 90 days, repointing the alias

◆ PAUSE AND DECIDE

Why, and how should the requirement be met?

- A

 90 days is below the minimum
90 days is exactly the minimum for automatic rotation, so the period is fine. The key's origin is what rejects the call.
- B

 Not supported for imported material; use on-demand rotation
Correct. Automatic rotation requires AWS-generated material. On-demand rotation for imported keys arrived in June 2025 and keeps the ARN and alias unchanged.
- C

 Convert to a multi-Region key first
You cannot convert a single-Region key at all, and multi-Region status has nothing to do with whether imported material can rotate.
- D

 New key every 90 days, repoint the alias
The pre-2025 workaround, and it breaks the stated requirement – the ARN changes, and hundreds of resources reference it.

THE SIGNAL

'Without changing the key ARN' rules out the workaround, and the key's EXTERNAL origin rules out the automatic path.

A retailer creates a multi-Region key in eu-west-1 with a carefully scoped key policy naming three roles, then replicates it to us-east-1 and ap-southeast-2 for disaster recovery.

Six months later an audit finds the us-east-1 replica has a key policy granting a fourth role that was never approved. A local administrator had added it. The team believed replica policies were inherited from the primary.

What is true, and what should the retailer do?

- ☐ A Replica policies are inherited; the audit finding is a console display issue
- ☐ B Replicating a key copies its policy permanently; re-replicate to restore it
- ☐ C Rotation is per-replica, so the policies diverged when the key rotated
- ☐ D Key policies are independent per replica; govern them with an SCP or RCP and Access Analyzer

◆ PAUSE AND DECIDE

What is true, and what should the retailer do?

- A

 Policies are inherited; display issue
The opposite of how multi-Region keys work. Each replica has its own independent policy, and a local administrator editing one is a real change.
- B

 Replication copies the policy permanently
Half true and misleading. A policy may be set at replication; it is not kept in step afterwards, which is exactly how they diverged.
- C

 Rotation is per-replica
Backwards - rotation is the one shared property, controlled only on the primary. Policies are the independent ones.
- D

 Policies are independent; govern with SCP/RCP and Access Analyzer
Correct. Same key material, separate governance. Controlling who may edit a key policy is an organisation-level control, not a KMS feature.

THE SIGNAL

Multi-Region keys share material and rotation. They share nothing about who may use them. That split is the exam point.

A government contractor must satisfy a regulator that cryptographic key material protecting classified data is never present within a cloud provider's infrastructure, and that the contractor can render the data unreadable unilaterally at any moment.

The data itself is stored in S3, and the applications reading it must continue to use ordinary AWS SDK calls without modification.

What should the contractor use?

- A An external key store, with key material in the contractor's own key manager
- B A CloudHSM key store, with key material in a dedicated CloudHSM cluster
- C A customer managed key with imported key material and a short expiry
- D Client-side encryption with keys held on-premises and ciphertext uploaded to S3

◆ PAUSE AND DECIDE

What should the contractor use?

- A

 External key store
Correct. Material never enters AWS, every operation happens in the contractor's HSM, and the key still presents as an ordinary KMS ARN so the SDK calls are unchanged.
- B

 CloudHSM key store
Single-tenant hardware the contractor controls – and it sits inside AWS infrastructure, which the requirement excludes explicitly.
- C

 Imported key material with a short expiry
The strongest distractor. Expiry does give unilateral revocation, but the material is imported into KMS, so it is present in AWS. That fails the first requirement.
- D

 Client-side encryption from on-premises
Satisfies both security requirements and breaks the third – the applications would need rewriting to encrypt and decrypt themselves.

THE SIGNAL

Three requirements. Option C fails one, option B fails one, option D fails a different one. Only A satisfies all three.

An airline replicates operational data from eu-west-1 to us-east-1 continuously. During a Regional failover exercise, applications in us-east-1 could not decrypt any replicated data, because the KMS key lives in eu-west-1 and cross-Region KMS calls failed.

The requirement is that us-east-1 can decrypt everything with no dependency on eu-west-1, and that no data is re-encrypted during the migration.

What should the airline implement?

- ☐ A Enable automatic key rotation and set the eu-west-1 key to replicate its material
- ☐ B Create a us-east-1 key, re-encrypt all replicated data with it, and repoint the applications
- ☐ C Create a multi-Region key and replicate it to us-east-1, migrating data to it going forward
- ☐ D Add a us-east-1 role to the eu-west-1 key policy and call KMS cross-Region

◆ PAUSE AND DECIDE

What should the airline implement?

- A

 Rotation replicates the material
Rotation changes material within a key; it does not create a key in another Region. An existing single-Region key cannot become multi-Region.
- C

 Multi-Region key, replicated, data migrated forward
Correct. Replicas share material and can decrypt each other's ciphertext with no cross-Region call - which is exactly what failover needs.
- B

 New key in us-east-1 and re-encrypt everything
It works, and the requirement says no data is re-encrypted during the migration. It is also a large, risky operation over live data.
- D

 Cross-account policy and cross-Region calls
This is the architecture that just failed. The failover scenario is precisely the case where eu-west-1 is unreachable.

THE SIGNAL

The honest part: the existing single-Region key cannot be converted, so old ciphertext still needs the old key. Plan the cutover.

Six things to carry forward

- ◆ Rotation changes material, never the ARN or alias.
- ◆ Automatic rotation: symmetric customer managed only, 90 to 2,560 days.
- ◆ Imported material has on-demand rotation only, since June 2025.
- ◆ MRKs share material and rotation. Policies and grants are per-Region.
- ◆ You cannot convert a single-Region key.
- ◆ Imported material is in AWS. External key store material never is.

ON THE EXAM

Next: encryption at rest across the storage services, and a default that changed in April 2026.